

CO 3 AT2

A JOSHITHA

ITA1407 ETHICAL HACKING

192421291

Q1. How would you identify and prioritize vulnerabilities after discovering multiple open ports during a port scan? Explain your approach.

Answer

Port scanning helps identify services running on a target system. After discovering multiple open ports, the next step is to identify vulnerabilities associated with those services and prioritize them based on risk.

First, I would identify the services running on each open port and determine their versions. Then, I would check whether the services contain known vulnerabilities or misconfigurations. Services that are publicly accessible and associated with sensitive data would receive higher priority.

The prioritization process would consider:

- Severity of the vulnerability
- Ease of exploitation
- Availability of public exploits
- Business impact if exploited
- Exposure to external networks

Vulnerability Prioritization

Risk Level	Description	Example
Critical	Immediate compromise possible	Remote Code Execution
High	Significant security impact	Weak Authentication
Medium	Limited impact	Information Disclosure
Low	Minor security issue	Banner Disclosure

By prioritizing vulnerabilities according to risk and business impact, security teams can focus on addressing the most dangerous threats first.

Q2. A SYN scan and a TCP Connect scan produce different results on the same target. What factors could cause this difference, and how would you verify the findings?

Answer

SYN Scan and TCP Connect Scan use different methods to identify open ports. A SYN scan performs a half-open connection, while a TCP Connect Scan completes the full TCP handshake.

Different results may occur due to:

- Firewall filtering
- Intrusion Detection Systems (IDS)
- Intrusion Prevention Systems (IPS)
- Network latency
- Packet loss
- Host security policies

A firewall may allow complete TCP connections while blocking SYN packets. Similarly, an IDS may detect and interfere with one scan type but not the other.

To verify the findings:

1. Repeat both scans.
2. Compare the results.
3. Perform service version detection.
4. Use additional scanning methods.
5. Verify connectivity manually.

Different scan results often reveal the presence of security controls and help analysts better understand the target environment.

Q3. During a port scan, most ports appear as "filtered." What security mechanisms might be responsible, and what additional techniques would you use to gather more information?

A filtered port indicates that the scanner cannot determine whether a port is open or closed because packets are being blocked.

Common security mechanisms responsible for filtered ports include:

- Firewalls
- Access Control Lists (ACLs)
- Intrusion Prevention Systems
- Security Gateways
- Router Filtering Rules
- Host-Based Firewalls

Filtered ports suggest that security controls are actively protecting the system.

To gather additional information, the following techniques can be used:

- ACK Scanning
- FIN Scanning
- NULL Scanning
- XMAS Scanning
- Service Version Detection
- Banner Grabbing
- Traceroute Analysis

These techniques help identify firewall behavior and provide additional insight into the network's security configuration.

Port State Analysis

Port State	Meaning
Open	Service is actively accepting connections
Closed	Host is reachable but no service is running
Filtered	Firewall or security device blocks probes

Understanding filtered ports helps security professionals assess the effectiveness of defensive controls and identify possible attack paths.

Q4. Compare TCP, UDP, and Stealth (SYN) Port Scanning Techniques. In which scenarios would each be the most effective, and what are their advantages and limitations?

Answer

Port scanning techniques differ in their speed, reliability, detectability, and purpose. TCP Connect Scan, UDP Scan, and SYN Scan are among the most commonly used methods during security assessments.

Comparison of Scanning Techniques

Feature	TCP Connect Scan	UDP Scan	SYN (Stealth) Scan
Protocol Used	TCP	UDP	TCP
Connection Method	Full TCP Handshake	UDP Request	Half-Open Handshake
Speed	Moderate	Slow	Fast
Accuracy	High	Medium	High
Detection Probability	High	Medium	Low
System Logs Generated	Yes	Limited	Minimal
Administrative Privileges	Not Required	Not Required	Required

Best Use Case	General Port Scanning	DNS, SNMP, DHCP Discovery	Penetration Testing
Main Advantage	Reliable Results	Detects UDP Services	Fast and Stealthy
Main Limitation	Easily Detected	Slow and Less Reliable	Requires Elevated Privileges

Analysis

TCP Connect Scan

- Completes the full TCP handshake.
- Reliable and accurate.
- Suitable for routine security assessments.
- Easily detected and logged by target systems.

UDP Scan

- Used to discover UDP-based services.
- Effective for identifying DNS, SNMP, and DHCP services.
- Slower because many UDP services do not respond consistently.

SYN Scan

- Performs a half-open connection.
- Faster and stealthier than TCP Connect Scan.
- Generates fewer logs on the target.
- Commonly used during penetration testing engagements.

Conclusion

TCP Connect Scan is best for reliability, UDP Scan is essential for discovering UDP services, and SYN Scan is preferred when speed and stealth are important.

Q5. Suppose you are conducting an authorized security assessment and discover critical services (such as SSH, FTP, and database ports) exposed to the internet. How would you assess the risks and recommend mitigation strategies?

Answer

Exposed critical services increase the attack surface of an organization and may provide attackers with opportunities to gain unauthorized access, steal data, or disrupt operations.

Risk Assessment

Service	Port	Risk Level	Potential Threat
SSH	22	High	Brute-force attacks, weak passwords
FTP	21	High	Credential theft, unauthorized file access
MySQL	3306	Critical	Database compromise, data leakage
MSSQL	1433	Critical	Unauthorized database access
PostgreSQL	5432	Critical	Exposure of sensitive information

Analysis of Risks

SSH

- Provides remote administration capabilities.
- Weak credentials may allow attackers to gain system access.
- Outdated versions may contain exploitable vulnerabilities.

FTP

- Transfers credentials in plain text.
- Vulnerable to interception and credential theft.
- May expose sensitive files.

Database Services

- Contain valuable organizational data.
- Direct exposure can lead to unauthorized access, data theft, and data manipulation.

Conclusion

Critical services exposed to the internet present significant security risks. Proper access controls, secure configurations, regular patching, and continuous monitoring are essential to reduce the attack surface and protect organizational assets.